

웹서비스 모의해킹 결과보고서

공공자전거 통합운영 웹서비스 및 보안 로그 연계 검증

구분	내용
점검 대상	사용자 서비스(5000), 관리자 서비스(6001), 협력업체 서비스(7000)
주요 인프라	WAF·WEB·DNS(DMZ VLAN 10), DB·LOG/Wazuh(내부 서버망 VLAN 15)
점검 기간	2026 년 7 월
보고서 성격	교육용 프로젝트 모의해킹 및 탐지 검증 결과
분류	대외비 / 프로젝트 제출용

작성일 2026.07.30

문서 관리	
항목	내용
문서명	또롱이 공공자전거 통합운영기관 웹서비스 모의해킹 결과보고서
버전	v1.0
작성 기준	제공된 공격 시나리오 및 증적 화면
배포 대상	프로젝트 지도자 및 팀원
보안 등급	프로젝트 내부 자료

유의사항

- 본 보고서는 교육용으로 구축한 또롱이 공공자전거 통합운영기관 환경을 대상으로 수행한 모의해킹 결과이다.
- 점검 결과는 제공된 요청·응답, 데이터베이스 조회, 애플리케이션 로그 및 Wazuh Alert 증적을 근거로 작성하였다.
- 공격 재현은 승인된 실습 환경에서만 수행하며 실제 운영 시스템에 동일 기법을 적용해서는 안 된다.

목차

번호	구성
1	점검 개요 및 대상 환경
2	수행 방법 및 위험도 기준
3	종합 결과
4	상세 취약점 분석
5	종합 개선 계획
6	재점검 기준 및 결론

1. 점검 개요 및 대상 환경

1.1 점검 목적

- 사용자·관리자·협력업체 서비스에서 발생할 수 있는 인증·인가, 데이터 무결성, 동시성, 설정 오류 및 감사 추적 취약점을 확인한다.
- 공격 행위가 애플리케이션 로그와 Wazuh 에 정상 수집·탐지되는지 검증한다.
- 확인된 취약점에 대해 서비스 구조에 맞는 보완 대책과 사고 대응 절차를 제시한다.

1.2 대상 서비스

구분	서비스/자산	포트·대역	주요 기능
DMZ 서버망	WEB 서버	192.168.10.0/24	USER·ADMIN·PARTNER 통합 웹 애플리케이션
사용자 서비스	USER	TCP 5000	회원, 대여, 반납, 이용권, 이용내역

구분	서비스/자산	포트·대역	주요 기능
관리자 서비스	ADMIN	TCP 6001	부서별 관리자 기능 및 운영 관리
협력업체 서비스	PARTNER	TCP 7000	정비·자전거 상태·재배치 업무
내부 서버망	DB 서버	192.168.15.0/24 / TCP 3306	인증·핵심·로그 데이터 저장
내부 서버망	LOG/Wazuh 서버	192.168.15.0/24	서버·보안장비 로그 수집 및 탐지

1.3 네트워크 분리 구조

구분	인터페이스	VLAN	게이트웨이	네트워크
DMZ 서버망	SERVER_NETWORK	10	192.168.10.1	192.168.10.0/24
내부 서버망	INTERNAL_DB	15	192.168.15.1	192.168.15.0/24
경영기획부	MGMT_DEPT	20	192.168.20.1	192.168.20.0/24
정보보안운영부	SECURITY_NETWORK	30	192.168.30.1	192.168.30.0/24
자전거운영부	BIKE_DEPT	40	192.168.40.1	192.168.40.0/24
시설정비부	MAINT_DEPT	50	192.168.50.1	192.168.50.0/24
고객서비스부	CS_DEPT	60	192.168.60.1	192.168.60.0/24

로그 수집 구조

WAF, WEB, DNS, DB, pfSense 및 Snort 에서 발생한 로그를 내부 서버망의 LOG/Wazuh 서버로 수집하여 통합 분석한다. 부서 VLAN 에는 업무용 PC 만 배치하고 서버는 배치하지 않는다.

2. 수행 방법 및 위험도 기준

2.1 수행 절차

단계	수행 내용	산출물
1. 정보 수집	서비스 경로, 세션, 객체 식별자, QR 구조 및 공개 경로 확인	대상·요청 형식
2. 취약점 재현	Burp Repeater, 병렬 요청, 직접 URL 요청 및 운영정보 변경	HTTP 요청·응답
3. 영향 확인	화면, DB 상태, 파일 내용 및 감사로그 확인	영향 증적
4. 탐지 검증	애플리케이션 JSON 로그, Wazuh archives/alerts, Dashboard 확인	Rule ID·Level·이벤트
5. 개선안 수립	원인별 기술적 조치, 사고 대응 및 재검증 기준 제시	개선 계획

2.2 위험도 평가 기준

등급	판단 기준	조치 우선순위
Critical	대규모 권한 탈취·원격 코드 실행 등 즉각적 침해 가능	즉시
High	타 사용자 데이터 변조, 핵심 업무 무결성 훼손, 민감 자료 노출	최우선
Medium	제한적 악용, 탐지·감사 기능 저하, 추가 조건이 필요한 공격	단기
Low	영향이 제한적이거나 정보성 문제	중장기

평가 방식	본 보고서의 위험도는 공격 성공 여부, 영향 범위, 재현 난이도, 필요한 권한과 현재 탐지 수준을 함께 고려한 프로젝트 기준 평가이다.
-------	---

3. 종합 결과

3.1 취약점 요약

ID	분류	점검 항목	위험도	판정
A01	Broken Access Control	타 사용자 대여정보 조회 및 강제 반납	High	취약점 확인
A02	Cryptographic Failures	예측 가능한 Base64 QR 토큰 변조 시도	Medium	변조 구조 확인·시도 탐지
A04	Insecure Design	동시 요청을 이용한 동일 자전거 중복 대여	High	취약점 확인
A05	Security Misconfiguration	운영자료 비인증 다운로드	High	취약점 확인
A09	Security Logging and Monitoring Failures	운영정보 연속 변경 및 감사 추적정보 부족	High	취약점 확인

3.2 핵심 결과

- 대여 번호에 대한 소유권 검증이 없어 다른 사용자의 대여정보를 조회하고 강제로 반납할 수 있었다.
- QR 값이 Base64 평문 구조로 분석되었으며 임의의 자전거 ID 를 포함한 토큰을 생성할 수 있었다. 제공된 증적에서는 위조 요청이 invalid_qr_attempt 로 차단·탐지되었다.
- 서로 다른 사용자 세션이 동일 자전거 QR 을 병렬 요청했을 때 두 대여가 모두 성공하여 동일 자전거의 중복 대여가 발생하였다.
- 협력업체 운영자료가 정적 공개 경로에 저장되어 로그인 없이 CSV·JSON 파일을 다운로드할 수 있었다.
- 협력업체가 자전거 상태와 배치 위치를 연속 변경할 수 있었으나 대상·행위자·변경 전후 값이 감사로그에 충분히 남지 않았다.

3.3 탐지 연계 결과

항목	주요 이벤트/Rule	결과
----	-------------	----

항목	주요 이벤트/Rule	결과
비인가 대여 객체 접근	rental_detail_owner_mismatch / rental_return_owner_mismatch	Wazuh Alert 및 Dashboard 확인
위조 QR 입력	invalid_qr_attempt / Rule 110600	실패 이벤트 및 공격자 정보 탐지
동시 대여 경쟁 구간	race_window_enter / race_window_exit / rental_started	동일 bicycle_id 복수 성공 이벤트 확인
운영자료 노출	/static/exports/ 접근	HTTP 200 다운로드 접근 탐지
감사정보 부족 운영변경	operational_change_without_audit_context / 114401:114402	원본 로그 및 상관 Alert 확인

시나리오 1

A01 Broken Access Control

타 사용자 대여정보 조회 및 강제 반납

항목	내용
사용자 A	test1 / user_id=70
사용자 B	test2 / user_id=71
공격 내용	test1 세션으로 test2 대여 조회·반납
탐지 이벤트	rental_detail_owner_mismatch, rental_return_owner_mismatch

취약점 개요

대여 상세 조회와 반납 처리 과정에서 요청한 rental_id 가 현재 로그인 사용자의 소유인지 검증하지 않아, 공격자가 다른 사용자의 대여번호를 지정해 상세정보를 조회하고 대여 상태를 강제로 변경할 수 있었다.

발생 원인

- 상세 조회와 반납 처리 쿼리가 rental_id 만 기준으로 객체를 조회한다.
- 인증 여부는 확인하지만 해당 객체가 로그인 사용자 소유인지 확인하는 객체 단위 인가가 누락되었다.
- GET 조회와 POST 상태변경 양쪽에서 동일한 결함이 반복되어 영향이 정보노출에서 데이터 변조로 확대되었다.

공격 영향

- 타 사용자의 자전거·대여시간·대여상태 등 이용정보 노출
- 정상 사용자의 대여가 임의 반납 처리되어 서비스 이용 방해
- 요금·이용권·자전거 상태의 무결성 훼손
- 다수 rental_id 순회 시 대량 개인정보 조회·변조 가능

최종 판정

타 사용자 대여정보 조회 및 강제 반납 성공 → A01 Broken Access Control 취약점 확인

공격 재현 및 탐지 증적

시나리오 1 증적 1. 타사용자 대여상세 조회

또롱이 공공자전거 통합운영기관

서비스 홈 대여소 조회 이용권 구매 이용내역 공지사항 문의사항 이용약관

USER01님 로그아웃

대여 중

이용내역 RENTAL DETAIL

대여 상세

자전거 이용정보와 반납 상태를 확인하세요.

자전거 번호 BIKE-007 QR N20X	배터리 99%	사용 이용권 7일권 PASS-7D
대여번호 #46	이용자 USER01 user01	출발 대여소 시청역 대여소 STATION-01
반납 대여소 반납 대기	대여 시작 2026-07-30 08:29:51	반납 시작 -
이용시간 이용 중	초과 이용요금 0원	

RETURN BICYCLE

자전거 반납

반납할 대여소를 선택해 주세요.

반납 대여소

반납 대여소 선택

자전거 반납

그림. 타사용자 대여상세 조회

시나리오 1 증적 2. 대여 ID 변조 요청

Request

Pretty Raw Hex

```

1 GET /rental/detail?rental_id=46 HTTP/1.1
2 Host:
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://
9 Cookie: session=
  .eJyVspLzElVslIKDXNMjBS0lEqys8B8UuLU4uAPBAVn5miZGVoZArhQdWdMED1tQCGUxP4.amsN
  Og.CG_kBNYWZga0k00fISJFALPFIPI
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
    
```

그림. 대여 ID 변조 요청

시나리오 1 증거 3. WAF 강제반납 탐지

index	wazuh-alerts-4.x-2026.08.03
agent.id	005
agent.ip	100.104.251.116
agent.name	ttorongi-waf
full_log	Apache-Error: [file "apache2_util.c"] [line 275] [level 3] [client 192.168.10.1] ModSecurity: Warning. Pattern match "[0-9]+\$" at ARGS:rental_id. [file "/etc/modsecurity/blueteam.conf"] [line "105"] [id "300024"] [msg "[TTORONGI-01][A01][WAF] Rental Return Object Identifier Request Detected"] [severity "CRITICAL"] [tag "TTORONGI-01"] [tag "OWASP-A01"] [tag "IDOR"] [hostname "100.104.251.116"] [uri "/rental/return-hv-id"] [unique id "am
id	1785717493.118226
input.type	log
location	/var/log/apache2/modsec_audit.log
manager.name	logserver
rule.description	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 요청 탐지
rule.firedtimes	4
rule.groups	ttorongi, waf, scenario01, owasp_a01, ttorongi_attack, A01, idor, waf, return_request
rule.id	120024
rule.level	11
rule.mail	false
timestamp	Aug 3, 2026 @ 09:38:13.145

그림. WAF 강제반납 탐지

시나리오 1 증거 4. Wazuh 탐지목록

183 hits					
Aug 3, 2026 @ 07:45:37.550 - Aug 3, 2026 @ 10:45:37.550					
Export Formatted Reset view 678 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Aug 3, 2026 @ 09:40:51.142	ttorongi-waf	PAM: Login session opened.	3	5501	
Aug 3, 2026 @ 09:40:51.140	ttorongi-waf	Successful sudo to ROOT executed.	3	5402	
Aug 3, 2026 @ 09:38:13.145	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 요청 탐지	11	120024	
Aug 3, 2026 @ 09:38:13.143	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 요청 탐지	11	120024	
Aug 3, 2026 @ 09:38:07.226	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요청 탐지	8	120023	
Aug 3, 2026 @ 09:38:07.220	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요청 탐지	8	120023	

그림. Wazuh 탐지목록

시나리오 1 증적 5. 보안로그 상세

```
{
  "file": "/var/log/apache2/ttorongi-user-waf-error.log",
  "message": "[Mon Aug 03 00:38:12.895980 2026] [security2:error] [pid 2274:tid 133277851539136] [client 192.168.10.1:45447] [client 192.168.10.1] ModSecurity: Warning. Pattern match \"^[0-9]+$\" at ARGS:rental_id. [file \"/etc/modsecurity/blueteam.conf\"] [line \"105\"] [id \"300024\"] [msg \"[TTORONGI-01][A01][WAF] Rental Return Object Identifier Request Detected\"] [severity \"CRITICAL\"] [tag \"TTORONGI-01\"] [tag \"OWASP-A01\"] [tag \"IDOR\"] [hostname \"100.95.198.24\"] [uri \"/rental/return-by-id\"] [unique_id \"am_i9E_LZGpLhKCwf_IqewAAABI\"], referer: http://100.95.198.24/rental/detail?rental_id=69\"
}
{
  \"file\": \"/var/log/apache2/ttorongi-user-waf-error.log\",
  \"message\": \"[Mon Aug 03 00:47:02.677872 2026] [security2:error] [pid 2274:tid 133277331486400] [client 192.168.10.1:9543] [client 192.168.10.1] ModSecurity: Warning. Pattern match \"^[0-9]+$\" at ARGS:rental_id. [file \"/etc/modsecurity/blueteam.conf\"] [line \"105\"] [id \"300024\"] [msg \"[TTORONGI-01][A01][WAF] Rental Return Object Identifier Request Detected\"] [severity \"CRITICAL\"] [tag \"TTORONGI-01\"] [tag \"OWASP-A01\"] [tag \"IDOR\"] [hostname \"100.95.198.24\"] [uri \"/rental/return-by-id\"] [unique_id \"am_lBk_LZGpLhKCwf_IqkAAAABc\"], referer: http://100.95.198.24/history\"
}
```

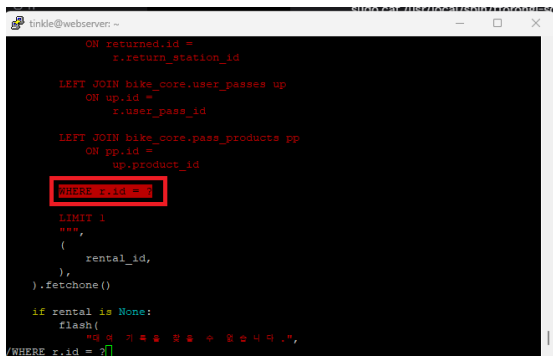
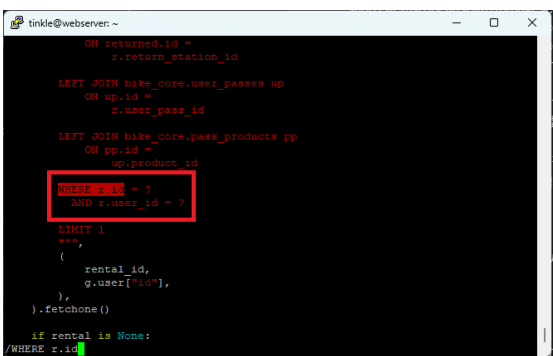
그림. 보안로그 상세

개선 방안

통제 영역	상세 적용 내용
애플리케이션 인가	모든 조회·반납 쿼리에 user_id=current_user.id 조건을 포함하고 불일치 시 403 을 반환한다.
서비스 로직	대여 상태, 소유자, 반납 가능 조건을 상태변경 직전에 다시 검증한다.
탐지·차단	owner_mismatch 반복 시 세션 만료, 계정 잠금 및 WAF 속도 제한을 연계한다.
검증	다른 사용자의 rental_id 를 직접·순차·무작위로 요청해 모두 거부되는지 확인한다.

개선 적용 코드

대여정보 조회·반납 처리 시 요청된 rental_id 만 사용하던 로직을 수정하여, 현재 로그인 사용자의 소유권을 함께 검증하도록 적용하였다. 타 사용자 대여 객체에 대한 조회 및 반납 요청은 차단된다.

변경 전	변경 후
 <pre>ON returned_id = r.return_station_id LEFT JOIN bike_core.user_passes up ON up.id = r.user_pass_id LEFT JOIN bike_core.pass_products pp ON pp.id = up.product_id WHERE r.id = ? LIMIT 1 """ (rental_id,).fetchone() if rental is None: flash("대여 객체를 찾을 수 없습니다.",) /WHERE r.id = ?</pre>	 <pre>ON returned_id = r.return_station_id LEFT JOIN bike_core.user_passes up ON up.id = r.user_pass_id LEFT JOIN bike_core.pass_products pp ON pp.id = up.product_id WHERE r.id = ? AND r.user_id = ? LIMIT 1 """ (rental_id, g.user["id"],).fetchone() if rental is None: flash("대여 객체를 찾을 수 없습니다.",) /WHERE r.id = ?</pre>

대응 전략

1. Alert 에서 공격 계정, source_ip, rental_id, bicycle_id 와 요청시각을 확보한다.
2. 공격 세션을 즉시 만료하고 계정을 임시 잠금한다.
3. 강제 반납된 레코드와 자전거 상태를 확인하여 실제 소유자의 활성 대여로 복구한다.
4. 동일 계정/IP 가 다른 rental_id 를 순회했는지 전체 로그를 조사한다.
5. 피해 사용자에게 비인가 조회·변경 사실과 조치 결과를 통지한다.

보안 적용 후 변화

보안조치 및 재검증 증적

시나리오 1 재검증 1. 소유권검증 재검증 차단

그림. 소유권검증 재검증 차단

재점검

성공 기준	test1 세션으로 test2 의 rental_id 를 조회·반납 요청한다. 두 요청 모두 403 이어야 하고 test2 의 대여상태와 자전거 상태가 변경되지 않아야 하며, Wazuh 에는 차단 이벤트가 기록되어야 한다.
-------	---

시나리오 2

A02 Cryptographic Failures

예측 가능한 Base64 QR 토큰 변조 시도

항목	내용
----	----

항목	내용
원본 대상	BIKE-002 / bicycle_id=2 / station_id=1
위조 대상	BIKE-005 / bicycle_id=5 / station_id=1
원본 QR	Mjox → 2:1
위조 QR	NTox → 5:1
요청 경로	POST /rental/qr

취약점 개요

QR 토큰이 bicycle_id:station_id 평문을 단순 Base64 로 인코딩한 형태여서 구조와 값의 예측·변조가 가능했다. 다만 제공된 재현 증적에서는 위조 토큰 NTox 가 유효하지 않은 QR 로 처리되었고 Wazuh 에서 invalid_qr_attempt 로 탐지되었다.

발생 원인

- Base64 인코딩 값을 보안 토큰으로 사용하여 기밀성·무결성·진위 검증을 제공하지 못한다.
- 토큰에 전자서명, 만료시간, 난수, 일회성 사용 이력이 포함되지 않는다.
- 현재 별도 유효성 검사로 요청이 거부되더라도 구조 노출과 대량 변조 시도 가능성은 남는다.

공격 영향

- 토큰 구조 노출로 자전거 ID 와 대여소 ID 탐색 가능
- 서명 검증이 부재할 경우 다른 자전거 대상 토큰 위조 가능
- 만료·일회성 검증이 없으면 토큰 재사용 위험
- 다수 ID 에 대한 자동화된 변조 시도로 서비스 남용 가능

최종 판정

예측 가능한 Base64 QR 구조 및 변조 시도 확인, 서버 차단과 Wazuh 탐지 확인

공격 재현 및 탐지 증거

시나리오 2 증거 1. QR 대여 원본화면

그림. QR 대여 원본화면

시나리오 2 증거 2. Base64 토큰구조 확인

```
(sung@kali)-[~]
$ echo 'Mjox' | base64 -d
2:1

(sung@kali)-[~]
$ echo -n '3:1' | base64
Mzox
```

그림. Base64 토큰구조 확인

시나리오 2 증적 3. QR 토큰 변조요청

Request	
Pretty	Raw Hex
1 POST /rental/qr HTTP/1.1	
2 Host: [REDACTED]	
3 User-Agent: Mozilla/5.0 (X11; L: Gecko/20100101 Firefox/140.0	
4 Accept: text/html,application/xhtml+xml	
5 Accept-Language: en-US,en;q=0.5	
6 Accept-Encoding: gzip, deflate,	
7 Content-Type: application/x-www	
8 Content-Length: 12	
9 Origin: http://[REDACTED]	
10 Connection: keep-alive	
11 Referer: http://[REDACTED]/p;	
12 Cookie: session=	
13 .eJyrVspLzElVslIKDXNMjBU0lEqys:	
14 EDltQcGBxPl.amvqsA.i---JYrJXQvg,	
15 Upgrade-Insecure-Requests: 1	
16 Priority: u=0, i	
17 qr_code=Mjox	

그림. QR 토큰 변조요청

시나리오 2 증적 4. 변조토큰 요청응답

Original request		Response	
Pretty	Raw Hex	Pretty	Raw Hex Render
1 POST /rental/qr HTTP/1.1		1 HTTP/1.1 302 FOUND	
2 Host: [REDACTED]		2 Date: Fri, 31 Jul 2026 01:00:26 GMT	
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0		3 Server: unicorn	
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8		4 Content-Type: text/html; charset=utf-8	
5 Accept-Language: en-US,en;q=0.5		5 Content-Length: 203	
6 Accept-Encoding: gzip, deflate, br		6 Location: /history	
7 Content-Type: application/x-www-form-urlencoded		7 Vary: Cookie	
8 Content-Length: 12		8 Set-Cookie: session=	
9 Origin: http://[REDACTED]		9 .eJwtjUEPgjAMhf8K6RlNN7ZscjThYLxpPAkhUEY0Q0Y0x	
10 Connection: keep-alive		10 H-u6l6eXlf32u60DtOXbyFC0VlgezNA2IiCjFCDvvDsdogF	
11 Referer: http://[REDACTED]/passes?tab=rental&code=Mjox		11 lmdy02Q1aOpU0dOvL0eg75AARtIAkTp6oG-F4pjo7zEJKp7	
12 Cookie: session=		12 yxstvtfBbKFZmxye3SNACZdzdULFX-fXJJximJlktPcBSqX	
13 .eJyrVspLzElVslIKDXNMjBU0lEqys8B8UuLU4uAPBAVn5		13 Nj_59sdxFP1_FPKk.amvzqg.HhsHhzzKA4NLuw_eAxd7u9L	
14 miZGV0ZALhQdWdMEDltQcGBxPl.amvzcQ.gq4vZv9kbaDFL		14 YXXs; HttpOnly; Path=	
15 6YQG_UkOLANGzY		15 Keep-Alive: timeout=5, max=100	
16 Upgrade-Insecure-Requests: 1		16 Connection: Keep-Alive	
17 Priority: u=0, i		17	
18 qr_code=Mjox		18 <!doctype html>	
		19 <html lang=en>	
		20 <title>	
		21 Redirecting...	
		22 </title>	
		23 <h1>	
		24 Redirecting...	
		25 </h1>	

그림. 변조토큰 요청응답

시나리오 2 증적 5. invalid qr attempt Wazuh 상세

Table	JSON
index	wazuh-alerts-4.x-2026.08.03
agent.id	001
agent.ip	100.77.91.115
agent.name	ttorongi-web
data.bicycle_id	MTg0MTpnZTh0LVZRVnZ6OFJjckVEHjZyTURVafVoYWRmYTY4MjQwLWg5QmF5QXow
data.category	security
data.event_type	invalid_qr_attempt
data.http_method	POST
data.message	토큰 재사용 QR 코드 디코딩 시도
data.request_path	/rental/qr
data.result	failure
data.service	ttorongi-user
data.severity	warning
data.source_ip	192.168.10.1
data.timestamp	Aug 3, 2026 @ 13:42:10.814
data.user_id	125
decoder.name	json
full_log	{ "timestamp": "2026-08-03T04:42:10.814+00:00", "service": "ttorongi-user", "category": "security", "event_type": "invalid_qr_attempt", "severity": "warning", "result": "failure", "source_ip": "192.168.10.1", "message": "토큰 재사용 QR 코드 디코딩 시도", "user_id": "125", "bicycle_id": "MTg0MTpnZTh0LVZRVnZ6OFJjckVEHjZyTURVafVoYWRmYTY4MjQwLWg5QmF5QXow", "request_path": "/rental/qr", "http_method": "POST" }
id	1785732131.2989885
input.type	log
location	/var/log/ttorongi/application.json
manager.name	logserver
rule.description	도롱이 공공자전거 QR 코드 재사용: 토큰 MTg0MTpnZTh0LVZRVnZ6OFJjckVEHjZyTURVafVoYWRmYTY4MjQwLWg5QmF5QXow, IP 192.168.10.1
rule.firedtimes	1
rule.groups	ttorongi, ttorongi, invalid_qr, security_event
rule.id	110600
rule.level	8
rule.mail	false
timestamp	Aug 3, 2026 @ 13:42:11.828

그림. invalid qr attempt Wazuh 상세

개선 방안

통제 영역	상세 적용 내용
토큰 설계	bicycle_id, station_id, exp, nonce 를 포함하고 서버 비밀키 기반 HMAC 서명을 적용한다.
재사용 방지	nonce 또는 jti 를 서버 저장소에 기록해 사용 후 즉시 폐기한다.
유효기간	짧은 만료시간을 적용하고 서버 시간 기준으로 검증한다.
탐지·제한	invalid_qr_attempt 를 계정·IP·자전거별로 집계하여 속도 제한과 추가 인증을 수행한다.

개선 적용 코드

예측 가능한 QR 토큰 처리 방식을 난수 기반 토큰 검증 방식으로 변경하였다. 토큰 무결성·유효성 검증을 통과하지 못한 변조값과 재사용 요청은 대여 생성 단계에서 거부된다.

변경 전	변경 후
------	------

변경 전	변경 후
 <pre> def create_unsigned_qr_token(bicycle_id, station_id,): # SCENARIO2_MODE: VULNERABLE """ 자전거 ID와 대역은 ID와 Base64로 암호화한다. 비밀번호, 인증값과 같은 서버의 현재 토큰과도 비교하지 않으므로 공격자가 값을 위조하거나 재사용할 수 있다. """ token_payload = { "qr": "QR 값 재", } /def create_unsigned_qr_token </pre>	 <pre> def create_unsigned_qr_token(bicycle_id, station_id,): # SCENARIO2_MODE: SECURE_REPLAY_PROTECTION """ QR 생성 : bicycle_id:station_id:random_token 자전거를 현재 요구한 번호 토큰을 DB에서 조회한다. 토큰의 유효성, 기존 자전거에는 동일한 번호 토큰을 생성할 수 없도록 한다. """ /def create </pre>

대응 전략

1. 변조 QR 이벤트의 계정, source_ip, 입력값과 대상 자전거를 확보한다.
2. 동일 출발지에서 연속된 ID 탐색이나 토큰 재사용 여부를 확인한다.
3. 대여 생성 여부와 이용권·자전거 상태 변화를 DB 에서 점검한다.
4. 대량 시도 계정과 IP 를 제한하고 유출 가능성이 있는 토큰을 일괄 폐기한다.
5. 서명 키 노출이 의심되면 키를 교체하고 모든 기존 토큰을 무효화한다.

보안 적용 후 변화

보안조치 및 재검증 증적

시나리오 2 재검증 1. 난수토큰 적용화면

BICYCLE INFORMATION
자전거 확인
QR 인식 결과를 확인한 후 대여 버튼을 눌러 주세요.

QR 코드 또는 자전거 번호

MjoxOnZhbmRGUFIbXpMQUcxUW5nbGNpem9NZUdjcUFpQzZySzg1cHFBR2F1TFk=
조회

자전거 번호
BIKE-002
대여소
배터리
상태

시청역 대여소
86%
대여 가능

사용 이용권
7일권
기본 60분 · 초과 30분당 1,000원

자전거 대여하기

TEST QR
TTORONGI-001
BIKE-001

그림. 난수토큰 적용화면

시나리오 2 재검증 2. 변조토큰 재검증 차단

BICYCLE INFORMATION
자전거 확인
QR 인식 결과를 확인한 후 대여 버튼을 눌러 주세요.

QR 코드 또는 자전거 번호

MjoxOnZiRndwNnNyOWdaUkk2RmVBY0FPS1g4V2toLXhQR0dCS3BaSDICY2NMZkE=
조회

자전거 번호
BIKE-002
대여소
배터리
상태

시청역 대여소
86%
대여 가능

사용 이용권
7일권
기본 60분 · 초과 30분당 1,000원

자전거 대여하기

TEST QR
TTORONGI-001
BIKE-001

그림. 변조토큰 재검증 차단

재점검

성공 기준	서명이 없는 Base64 변조값, 만료 토큰, 이미 사용한 토큰을 각각 전송한다. 모두 대여 미생성·이용권 미차감이어야 하며 무결성·만료·재사용 사유가 구분된 Alert 가 생성되어야 한다.
-------	--

시나리오 3

A04 Insecure Design

동시 요청을 이용한 동일 자전거 중복 대여

항목	내용
사용자 A	test1 / user_id=70
사용자 B	test2 / user_id=71
대상 자전거	BIKE-011 / bicycle_id=11
QR 코드	MTE6MQ==
공격 방법	Burp Send group in parallel

취약점 개요

대여 가능 여부를 최초 조회한 이후 트랜잭션 수준의 동시성 제어와 상태 재검증 없이 처리하여, 서로 다른 두 사용자가 동일 자전거 QR 을 거의 동시에 전송할 경우 두 대여 요청이 모두 성공하였다.

발생 원인

- 가용 상태를 조회한 뒤 실제 대여 생성까지 경쟁 창이 존재한다.
- 동일 자전거 행에 대한 잠금, 조건부 UPDATE, rowcount 검증 또는 활성 대여 고유 제약이 없다.
- 두 트랜잭션이 과거의 available 상태를 각각 신뢰하여 모두 rental_started 를 생성한다.

공격 영향

- 동일 자전거에 활성 대여가 복수 생성되어 자산 상태 무결성 훼손
- 이용권·요금·대여시간이 사용자별로 잘못 계산될 가능성
- 실제 자전거 이용자와 시스템 대여자 불일치
- 대량 병렬 요청 시 운영 장애와 고객 분쟁 발생 가능

최종 판정	동시성 제어 부재로 동일 자전거 중복 대여 성공 → A04 Insecure Design 취약점 확인
-------	---

공격 재현 및 탐지 증적

시나리오 3 증적 1. 대여가능 자전거목록

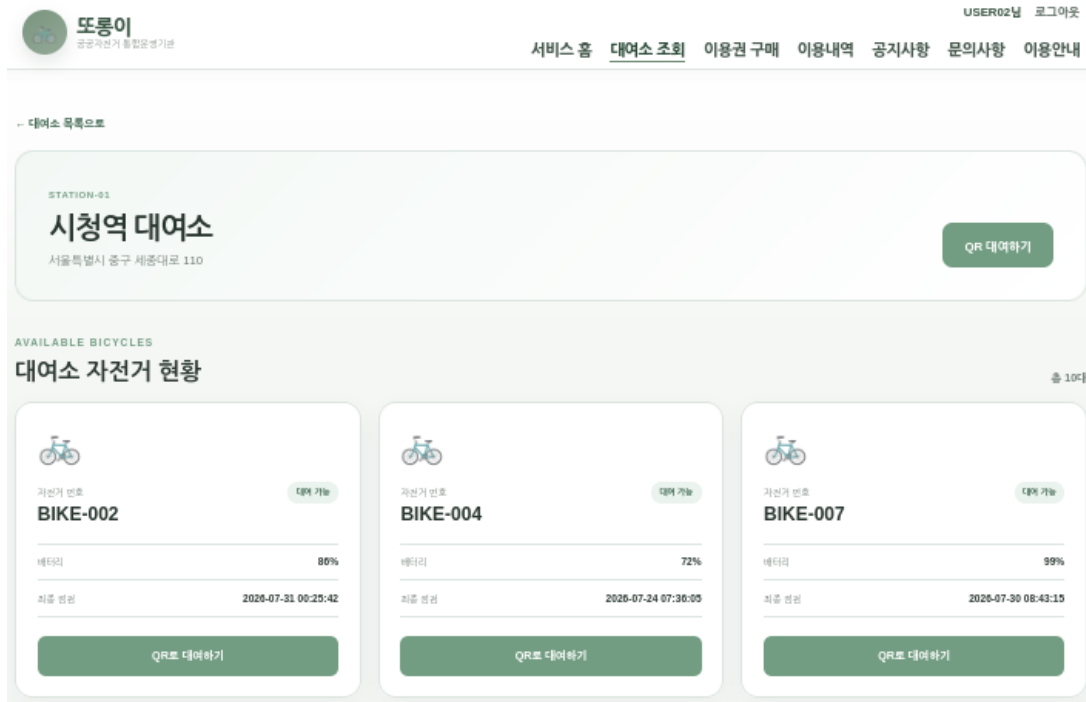


그림. 대여가능 자전거목록

시나리오 3 증적 2. 동일자전거 대여대상

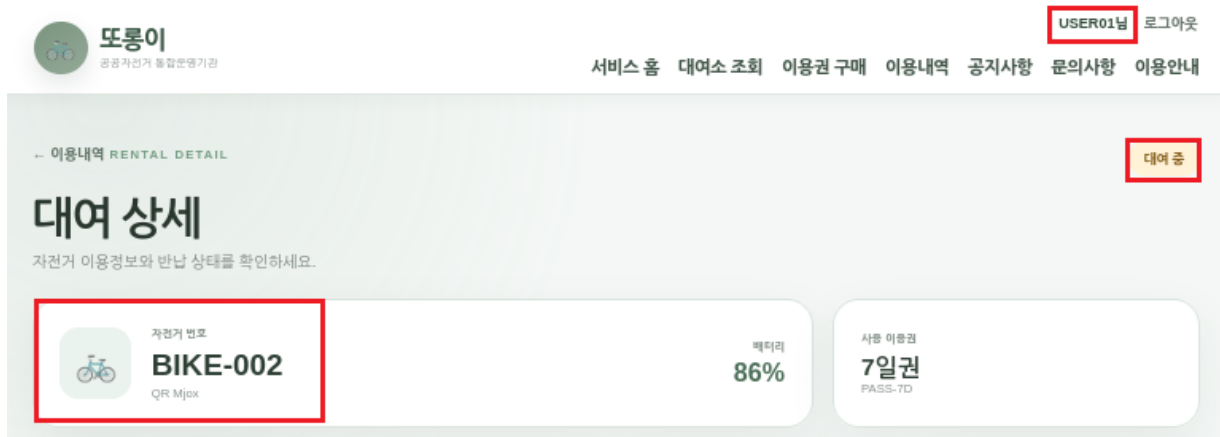


그림. 동일자전거 대여대상

시나리오 3 증적 3. 동시대여 요청화면

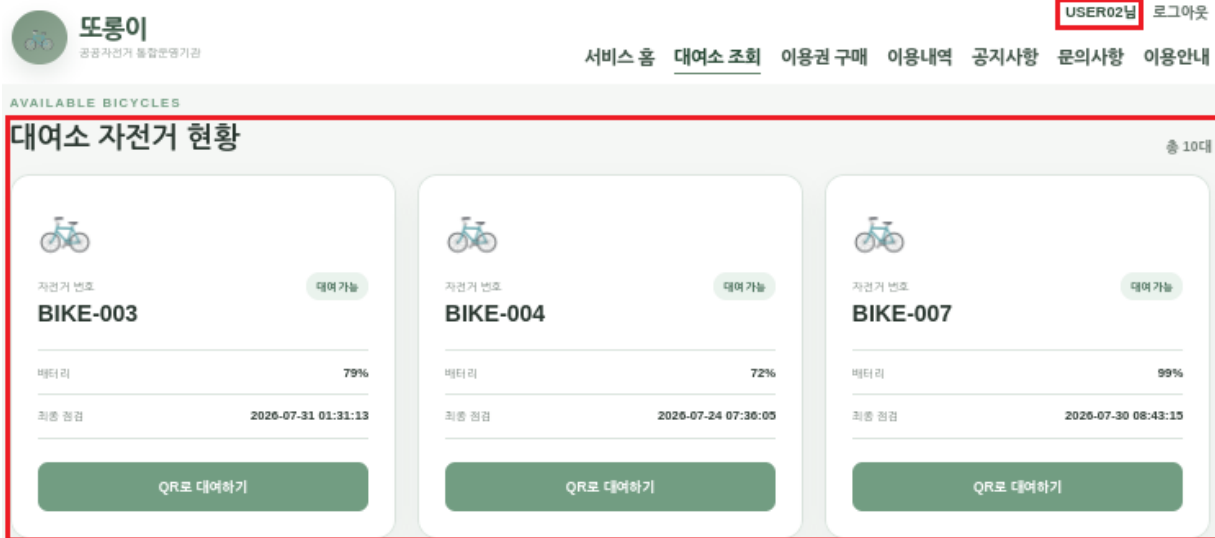


그림. 동시대여 요청화면

시나리오 3 증적 4. 동시요청 실행코드

```
(sung@kali)-[~]
$ URL="http://[redacted]/rental/qr"
QR="Mjox"

SESSION_A='.eJyrVspLzE1VsLIKDXYNMjBU0lEqys8B8UuLU4uAPBAVn5m1ZGVoZALhQdWdMED1tQCGBxP1.amv9Xg
.Q2NVwOMxaUmehDD1bStB7C0TwAw'
SESSION_B='.eJyrVspLzE1VsLIKDXYNMjBS0lEqys8B8UuLU4uAPBAVn5m1ZGVoZArhQdWdMED1tQCGUxP4.amv9kA
.oyVebjbeYtM_bTL4QeuLXFVN2Ek'

curl -s -i -X POST "$URL" \
-H "Content-Type: application/x-www-form-urlencoded" \
-H "Origin: http://[redacted]" \
-H "Referer: http://[redacted]/passes?tab=rental&code=Mjox" \
-b "session=$SESSION_A" \
--data "qr_code=$QR" > user_A_result.txt &

curl -s -i -X POST "$URL" \
-H "Content-Type: application/x-www-form-urlencoded" \
-H "Origin: http://[redacted]" \
-H "Referer: http://[redacted]/passes?tab=rental&code=Mjox" \
-b "session=$SESSION_B" \
--data "qr_code=$QR" > user_B_result.txt &

wait

echo "===== 사용자 A 결과 ====="
cat user_A_result.txt
echo
echo "===== 사용자 B 결과 ====="
cat user_B_result.txt
```

그림. 동시요청 실행코드

시나리오 3 증적 5. USER02 동일자전거 대여결과


또롱이
 공공자전거 통합운영기관

USER02님 [로그아웃](#)

[서비스 홈](#)
[대여소 조회](#)
[이용권 구매](#)
[이용내역](#)
[공지사항](#)
[문의사항](#)
[이용안내](#)

-- 이용내역 RENTAL DETAIL

대여 중

대여 상세

자전거 이용정보와 반납 상태를 확인하세요.



자전거 번호
BIKE-002
 QR Mjox

배터리
86%

사용 이용권
7일권
 PASS-7D

대여번호
 #53

이용자
USER02
 user02

출발 대여소
 시청역 대여소
 STATION-01

반납 대여소
 반납 대기

대여 시작
2026-07-31 02:18:28

반납 시작
 -

이용시간
 이용 중

초과 이용요금
0원

그림. USER02 동일자전거 대여결과

시나리오 3 증적 6. USER01 동일자전거 대여결과


또롱이
 공공자전거 통합운영기관

USER01님 [로그아웃](#)

[서비스 홈](#)
[대여소 조회](#)
[이용권 구매](#)
[이용내역](#)
[공지사항](#)
[문의사항](#)
[이용안내](#)

-- 이용내역 RENTAL DETAIL

대여 중

대여 상세

자전거 이용정보와 반납 상태를 확인하세요.



자전거 번호
BIKE-002
 QR Mjox

배터리
86%

사용 이용권
7일권
 PASS-7D

대여번호
 #52

이용자
USER01
 user01

출발 대여소
 시청역 대여소
 STATION-01

반납 대여소
 반납 대기

대여 시작
2026-07-31 02:18:28

반납 시작
 -

이용시간
 이용 중

초과 이용요금
0원

그림. USER01 동일자전거 대여결과

시나리오 3 증적 7. 동시요청 처리로그

```
{
  "timestamp": "2026-08-03T01:43:48.975+0000",
  "agent": "ttorongi-web",
  "rule_id": "120025",
  "rule_level": 8,
  "description": "[TORONGI-02][A02][Flask] 비정상 QR 토큰 제출 이벤트 탐지 : 사용자 142, IP 192.168.10.1, 경로 /rental/qr"
,
  "event_type": "invalid_qr_token",
  "user_id": "142",
  "source_ip": "192.168.10.1",
  "request_path": "/rental/qr",
  "result": "failure",
  "failure_reason": null,
  "full_log": "{ \"timestamp\": \"2026-08-03T01:43:48.670+00:00\", \"service\": \"ttorongi-user\", \"category\": \"security\", \"event_type\": \"invalid_qr_token\", \"severity\": \"warning\", \"result\": \"failure\", \"source_ip\": \"192.168.10.1\", \"message\": \"탐식이 유효하지 않거나 자전거 번호를 직접 입력한 대여 요청 차단 \", \"user_id\": 142, \"request_path\": \"/rental/qr\", \"http_method\": \"POST\" }"
}
{
  "timestamp": "2026-08-03T01:47:57.071+0000",
  "agent": "ttorongi-web",
  "rule_id": "120025",
  "rule_level": 8,
  "description": "[TORONGI-02][A02][Flask] 비정상 QR 토큰 제출 이벤트 탐지 : 사용자 142, IP 192.168.10.1, 경로 /rental/qr"
,
  "event_type": "invalid_qr_token",
  "user_id": "142",
  "source_ip": "192.168.10.1",
  "request_path": "/rental/qr",
  "result": "failure",
  "failure_reason": null,
  "full_log": "{ \"timestamp\": \"2026-08-03T01:47:55.919+00:00\", \"service\": \"ttorongi-user\", \"category\": \"security\", \"event_type\": \"invalid_qr_token\", \"severity\": \"warning\", \"result\": \"failure\", \"source_ip\": \"192.168.10.1\", \"message\": \"탐식이 유효하지 않거나 자전거 번호를 직접 입력한 대여 요청 차단 \", \"user_id\": 142, \"request_path\": \"/rental/qr\", \"http_method\": \"POST\" }"
}
```

그림. 동시요청 처리로그

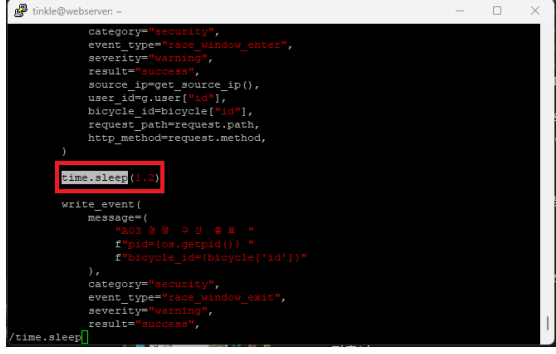
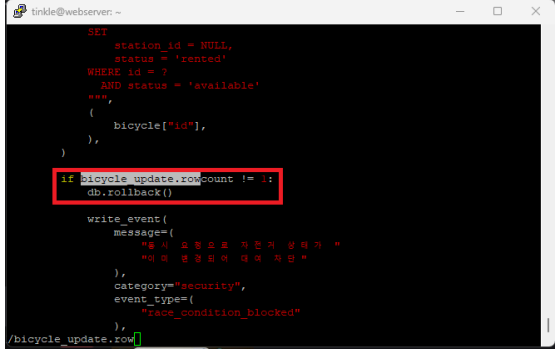
개선 방안

통제 영역	상세 적용 내용
트랜잭션	상태확인·자전거 점유·대여 생성·이용권 변경을 하나의 원자적 트랜잭션으로 처리한다.
행 잠금	SELECT ... FOR UPDATE 로 자전거 행을 잠그거나 조건부 UPDATE WHERE status=available 을 사용한다.
성공 판정	UPDATE rowcount 가 1 일 때만 대여 레코드를 생성하고 0 이면 이미 대여됨으로 반환한다.
DB 제약	동일 bicycle_id 의 활성 대여가 1 건을 초과하지 않도록 스키마 수준의 제약 또는 보조 잠금 테이블을 적용한다.
복구	중복 대여 탐지 시 후발 트랜잭션을 취소하고 이용권·자전거 상태를 자동 원복한다.

개선 적용 코드

대여 가능 여부 확인과 대여 생성을 분리 처리하던 로직에 트랜잭션 및 동시성 제어를 적용하였다. 동일 자전거에 병렬 요청이 발생해도 최초 요청만 처리되고 후속 요청은 실패하도록 개선하였다.

변경 전	변경 후
------	------

변경 전	변경 후
 <pre> category="security", event_type="race_window_enter", severity="warning", result="success", source_ip=get_source_ip(), user_id=get_userid(), bicycle_id=bicycle["id"], request_path=request.path, http_method=request.method,) time.sleep(1.0) write_event(message={ "A03 등록 구간 종료 " f"pid={os.getpid()} " f"bicycle_id={bicycle['id']}" }, category="security", event_type="race_window_exit", severity="warning", result="success",) time.sleep(1.0) </pre>	 <pre> SET station_id = NULL, status = 'rented' WHERE id = ? AND status = 'available') { bicycle["id"], },) if bicycle_update.rowcount != 1: db.rollback() write_event(message={ "동시 요청으로 자전거 잠금자 " "미리 발생하면 대여 차단" }, category="security", event_type={ "race_condition_blocked" },) bicycle_update.row </pre>

대응 전략

1. 동일 bicycle_id 의 rental_started 이벤트를 시간순으로 묶어 사용자와 rental_id 를 식별한다.
2. 실제 자전거 이용자를 확인하고 후발 또는 비정상 대여를 즉시 중지한다.
3. 잘못 차감된 이용권과 요금을 원복하고 자전거 상태를 단일 활성 대여 기준으로 정정한다.
4. 동일 시간대의 다른 자전거에도 병렬 공격이 있었는지 검색한다.
5. 취약 로직 수정 전까지 동일 자전거 요청을 직렬화하거나 임시 잠금 기능을 적용한다.

보안 적용 후 변화

보안조치 및 재검증 증적

시나리오 3 재검증 1. 재검증 활성대여 1 건

```
MariaDB [bike_core]> SELECT
->     bicycle_id,
->     COUNT(*) AS active_rental_count
-> FROM rentals
-> WHERE bicycle_id = 16
->     AND status = 'renting'
->     AND return_time IS NULL
-> GROUP BY bicycle_id;
```

bicycle_id	active_rental_count
16	1

1 row in set (0.001 sec)

그림. 재검증 활성대여 1 건

재점검

성공 기준

서로 다른 두 세션으로 동일 QR 을 병렬 전송한다. 정확히 한 요청만 성공하고 DB 의 동일 bicycle_id 활성 대여는 1 건이어야 하며 후발 요청은 충돌 차단 이벤트를 남겨야 한다.

시나리오 4

A05 Security Misconfiguration

운영자료 비인증 다운로드

항목	내용
서비스	협력업체 서비스 / TCP 7000
노출 파일	maintenance_work_orders.csv
노출 파일	bicycle_relocation.json
공격 조건	로그인 쿠키 없이 직접 요청
노출 경로	/static/exports/

취약점 개요

정비 작업과 자전거 재배치 자료가 웹 정적 디렉터리에 저장되어 인증·권한 확인 없이 고정 URL 로 다운로드 가능했다.

발생 원인

- 운영자료를 웹사이트의 static 하위에 저장하여 프레임워크가 인증 없이 직접 제공한다.
- 파일 URL 이 고정되고 예측 가능하며 접근 시 애플리케이션 권한 검사가 실행되지 않는다.
- HTTP 200 응답 후 탐지만 수행되어 기밀성 침해를 예방하지 못한다.

공격 영향

- 자전거 ID, 상태, 정비작업 및 재배치 정보 외부 노출
- 운영 패턴 분석을 통한 자산 절도·방해 공격 가능
- 고정 URL 공유·검색엔진·프록시 캐시를 통한 지속 노출
- 협력업체와 기관의 운영정보 기밀성 훼손

최종 판정

정적 경로를 통한 운영자료 비인증 다운로드 성공 → A05 Security Misconfiguration 취약점 확인

공격 재현 및 탐지 증적

시나리오 4 증적 1. 비인증파일 HEAD 요청

```
(sung@kali)-[~]
$ curl -i \
  http://100.77.91.115:7000/static/exports/maintenance_work_orders.csv
HTTP/1.1 200 OK
Server: gunicorn
Date: Fri, 31 Jul 2026 04:07:56 GMT
Connection: keep-alive
Content-Disposition: inline; filename=maintenance_work_orders.csv
Content-Type: text/csv; charset=utf-8
Content-Length: 1890
Last-Modified: Wed, 29 Jul 2026 06:50:13 GMT
Cache-Control: no-cache
ETag: "1785307813.6764941-1890-2273450683"
Accept-Ranges: bytes
Vary: Cookie
```

그림. 비인증파일 HEAD 요청

시나리오 4 증적 2. 비인증파일 응답확인

```
(sung@kali)-[~]
$ curl -i \
  http://[REDACTED]/static/exports/maintenance_work_orders.csv
HTTP/1.1 200 OK
Server: gunicorn
Date: Fri, 31 Jul 2026 04:07:56 GMT
Connection: keep-alive
Content-Disposition: inline; filename=maintenance_work_orders.csv
Content-Type: text/csv; charset=utf-8
Content-Length: 1890
Last-Modified: Wed, 29 Jul 2026 06:50:13 GMT
Cache-Control: no-cache
ETag: "1785307813.6764941-1890-2273450683"
Accept-Ranges: bytes
Vary: Cookie
```

그림. 비인증파일 응답확인

시나리오 4 증적 3. 운영자료 내용노출

```
(sung@kali)-[~]
$ curl -o maintenance_work_orders.csv \
  http://[REDACTED]/static/exports/maintenance_work_orders.csv
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             0         0      0     0      0     0      0
100    1890    100    1890    0        0    33789    0      0      0

(sung@kali)-[~]
$ head -n 10 maintenance_work_orders.csv
task_id,task_code,issue_type,issue_title,issue_description,administrator_request,priority,status,station_code,station_name,station_address,bicycle_code,qr_code,bicycle_status,battery_level,assigned_at,accepted_at,started_at,completed_at,cancelled_at,work_description,replaced_parts,additional_check,additional_check_detail,bicycle_result_status,report_status,created_at,updated_at
3,TASK-20260725-003,inspection,대여소 정기 안전점검,월간 정기점검 대상 대여소입니다., "거치대, 안내판, 주변 시설 및 대여소 운영 상태를 점검해 주세요.",normal,completed,STATION-03,을지로입구대여소,서울특별시 중구 을지로 42,,,,,2026-07-25 08:23:47,2026-07-28 02:15:46,2026-07-28 02:15:54,2026-07-28 02:16:39,,111,111,none,,available,submitted,2026-07-25 08:23:47,2026-07-28 02:16:39
2,TASK-20260725-002,battery,배터리 잔량 및 전원 상태 점검,자전거 단말기 전원이 간헐적으로 꺼진다는 신고가 접수되었습니다.,배터리 단자와 충전 상태를 확인하고 필요 시 정비 상태로 변경해 주세요.,high,completed,STATION-02,광화문 대여소,서울특별시 중로구 세종대로 172,BIKE-006,N_jox,available,100,2026-07-25 08:23:47,2026-07-28 02:10:29,2026-07-28 02:10:34,2026-07-28 02:10:48,,111,,none,,available,submitted,2026-07-25 08:23:47,2026-07-28 02:10:48
1,TASK-20260725-001,brake,브레이크 작동 불량 점검,사용자 신고를 통해 브레이크 반응이 느리다는 내용이 접수되었습니다.,브레이크 패드와 제동 케이블을 점검하고 작업 결과를 등록해 주세요.,urgent,completed,STATION-01,시청역 대여소,서울특별시 중구 세종대로 110,BIKE-001,MToy,available,88,2026-07-25 08:23:47,2026-07-25 13:17:57,2026-07-25 13:18:00,2026-07-25 13:18:48,,TEST,TEST,none,,maintenance,submitted,2026-07-25 08:23:47,2026-07-25 13:18:48
```

그림. 운영자료 내용노출

시나리오 4 증적 4. 직접경로 접근요청

```
(sung@ kali)-[~]
$ curl -i \
  http://100.95.198.24:7000/static/exports/maintenance_work_orders.csv
HTTP/1.1 403 Forbidden
Date: Fri, 31 Jul 2026 06:50:29 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Length: 280
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at 100.95.198.24 Port 7000</address>
</body></html>

(sung@ kali)-[~]
$ curl -i \
  http://100.95.198.24:7000/static/exports/bicycle_relocation.json
HTTP/1.1 403 Forbidden
Date: Fri, 31 Jul 2026 06:50:53 GMT
Server: Apache/2.4.58 (Ubuntu)
Content-Length: 280
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at 100.95.198.24 Port 7000</address>
</body></html>
```

그림. 직접경로 접근요청

시나리오 4 증적 5. Wazuh 비인증다운로드 탐지

	Aug 3, 2026 @ 16:01:05.013	logserver	TTORONGI pfSense blocked network traffic	5	100521
	Aug 3, 2026 @ 16:01:05.013	logserver	TTORONGI pfSense blocked network traffic	5	100521
	Aug 3, 2026 @ 16:01:05.012	logserver	TTORONGI pfSense blocked network traffic	5	100521
	Aug 3, 2026 @ 16:00:53.012	logserver	TTORONGI pfSense blocked network traffic	5	100521
	Aug 3, 2026 @ 16:00:51.740	logserver	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함	8	114401
	Aug 3, 2026 @ 16:00:50.991	logserver	TTORONGI pfSense blocked network traffic	5	100521
	Aug 3, 2026 @ 16:00:49.991	logserver	TTORONGI pfSense blocked network traffic	5	100521
	Aug 3, 2026 @ 16:00:47.905	ttorongi-waf	Agent event queue is back to normal load.	3	205
	Aug 3, 2026 @ 16:00:44.286	ttorongi-snort	Snort IDS/IPS network detection alert	7	100500

그림. Wazuh 비인증다운로드 탐지

시나리오 4 증적 6. Wazuh 탐지상세

† _index	wazuh-alerts-4.x-2026.08.03
† agent.id	000
† agent.name	logserver
† data.access_timestamp	2026-08-03T07:00:43.856+0000
† data.agent_name	ttorongi-web
† data.category	security
† data.event_type	operational_change_without_audit_context
† data.http_method	POST
† data.message	파트너 자전거 상태 변경 요청 이후 bike_status_changed 감사로그가 확인되지 않음
† data.request_path	/partner/bicycle/status
† data.result	success
† data.service	ttorongi-wazuh
† data.severity	high
† data.source_ip	192.168.10.2
📅 data.timestamp	Aug 3, 2026 @ 16:00:50.970
† decoder.name	json
† full_log	{ "timestamp": "2026-08-03T07:00:50.970+00:00", "service": "ttorongi-wazuh", "category": "security", "event_type": "operational_change_without_audit_context", "severity": "high", "result": "success", "source_ip": "192.168.10.2", "message": "파트너 자전거 상태 변경 요청 이후 bike_status_changed 감사로그가 확인되지 않음", "request_path": "/partner/bicycle/status", "http_method": "POST", "access_timestamp": "2026-08-03T07:00:43.856+0000", "agent_name": "ttorongi-web" }
† id	1785740451.5206176

그림. Wazuh 탐지상세

개선 방안

통제 영역	상세 적용 내용
저장 위치	운영자료를 DocumentRoot/static 외부의 비공개 디렉터리 또는 객체 저장소로 이동한다.
다운로드 API	로그인·역할·업무 범위를 검증하는 컨트롤러를 통해서만 파일을 전송한다.
임시 링크	외부 전달이 필요하면 짧은 만료시간과 사용자 바인딩이 있는 서명 URL 을 사용한다.
웹서버/WAF	/static/exports/를 즉시 차단하고 디렉터리 인덱싱·캐시를 비활성화한다.
노출 점검	기존 웹 캐시, 프록시, 백업과 검색엔진에 남은 사본을 조사·삭제한다.

개선 적용 코드

운영자료를 정적 공개 경로에서 직접 제공하지 않고, 인증·권한 검증을 수행하는 다운로드 처리 로직을 적용하였다. 비인증 사용자와 권한이 없는 계정의 직접 경로 접근은 차단된다.

보안 적용 코드

보안 적용 코드

```
tinkle@webserver: ~
    "warning",
    )

    return redirect(
        url_for("login")
    )

    g.current_partner = partner

# ===== SCENARIO4_MODE: SECURE START =====
@app.before_request
def protect_partner_export_static_files():
    """
    static/exports 경로의 운영자료를 비로그인 상태에서
    직접 내려받지 못하도록 차단한다.

    정상적인 내려받기 기능은 로그인 세션이 있을 때
    기존 Flask static 응답을 그대로 사용한다.
    """
    protected_prefix = (
        "/static/exports/"
    )

    @protected_partner
```

대응 전략

1. 접근 로그에서 다운로드 IP, 사용자 에이전트, 시각과 파일명을 확보한다.
2. 노출된 파일을 즉시 이동·삭제하고 경로를 WAF/pfSense 에서 차단한다.
3. 동일 경로의 전체 파일 목록과 과거 다운로드 이력을 조사한다.
4. 자료에 포함된 자전거·대여소·협력업체 정보의 악용 가능성을 평가한다.
5. 필요 시 관계 부서와 협력업체에 유출 범위와 후속 조치를 통지한다.

보안 적용 후 변화

보안조치 및 재검증 증적

시나리오 4 재검증 1. 재검증 직접접근 차단

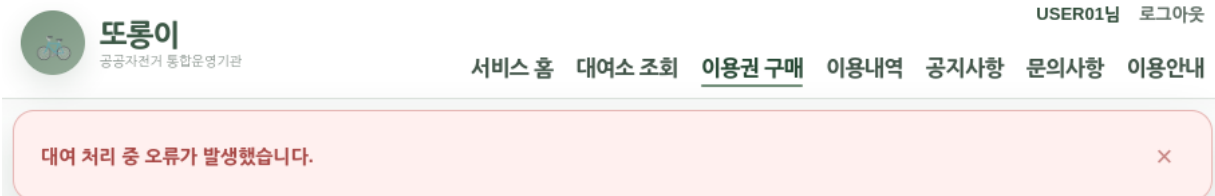


그림. 재검증 직접접근 차단

재점검

성공 기준

쿠키 없는 요청, 권한 없는 일반 사용자, 허용된 협력업체 사용자로 동일 파일을 요청한다. 앞의 두 요청은 401/403, 허용 사용자는 감사로그와 함께 정상 다운로드되어야 한다.

시나리오 5

A09 Security Logging and Monitoring Failures

운영정보 연속 변경 및 감사 추적정보 부족

항목	내용
대상 자전거	BIKE-006 / bicycle_id=6
상태 변경	maintenance → available
위치 변경	station_id=1 → station_id=5
공격 경로	/partner/bicycle/status, /partner/bicycle/relocate
탐지 이벤트	operational_change_without_audit_context

취약점 개요

협력업체 세션으로 정비 중 자전거의 상태와 배치 대여소를 연속 변경할 수 있었으며, 변경 사실은 로그에 남았지만 대상·행위자·변경 전후 값과 사유가 충분히 기록되지 않아 정확한 사고 추적과 원상복구가 어려웠다.

발생 원인

- 운영 상태 변경에 대한 승인·업무 규칙 검증이 충분하지 않다.
- 감사로그가 행위자, 대상, 변경 전후 값, 사유와 연관 작업지시서를 완전하게 보존하지 않는다.
- 업무 변경과 로그 저장에 별도 처리되어 실패 시 감사 흔적이 누락될 가능성이 있다.

공격 영향

- 정비 미완료 자전거가 대여 가능 상태로 전환되어 안전사고 가능
- 자전거 배치정보 변조로 운영·재배치 업무 혼선
- 행위자와 변경 전후 값 누락으로 책임 추적 및 복구 지연
- 내부자 또는 탈취 계정의 반복 조작을 사후에 입증하기 어려움

최종 판정

운영정보 변경은 성공했으나 감사 맥락이 부족하여 A09 취약점 확인

공격 재현 및 탐지 증적

시나리오 5 증적 1. 자전거상태 변경대상

도롱이 공공자전거 통합운영기관
정보보안운영부 관리자 시스템

최고관리자 권한으로 접속 중

← 자전거 목록

BICYCLE DETAIL

BIKE-026
QR Mz16NQ== - 청계광장 대여소

대여 가능 자전거 정보 수정

누적 대여: 0 건 총 이용 시간: 0 분 누적 이용 금액: 0 원 현재 배터리: 62 %

BICYCLE INFORMATION
자전거 정보

관리 번호	32
자전거 코드	BIKE-026
QR 코드	Mz16NQ==
배치 대여소	청계광장 대여소 · STATION-05
자전거 상태	대여 가능
배터리	62%
최근 점검	2026-07-24 07:36:05

CURRENT RENTAL
현재 이용 상태

현재 이 자전거를 이용 중인 사용자가 없습니다.

그림. 자전거상태 변경대상

시나리오 5 증적 2. 자전거상태 변경화면

BICYCLE CONFIGURATION

자전거 정보 수정
자전거 식별 정보와 배치-운영 상태를 설정합니다.

IDENTIFICATION
식별 정보

자전거 코드 필수 QR 코드 필수

BIKE-026 Mz16NQ==

영문 대문자, 숫자, 하이픈, 밑줄을 사용할 수 있습니다. 사용자 QR 대여 화면에서 입력하거나 스캔하는 값입니다.

OPERATION SETTINGS
운영 설정

배치 대여소 자전거 상태 필수

청계광장 대여소 · 6/12대 · 정상 대여 가능

운영 중단 또는 수동량이 가득 찬 대여소에는 배치할 수 없습니다. 사용자 QR 대여 화면에서 입력하거나 스캔하는 값입니다.

배터리 필수 최근 점검

62% 2026-07-24 07:36:05

배터리가 10% 미만이면 대여 가능 상태로 설정할 수 없습니다.

대여 가능 **정비 중** **고장** **예약**

정상 배치되어 사용자가 즉시 대여할 수 있는 상태입니다. 정비 작업 중이며 사용자가 대여 대상에서 제외됩니다. 고장이 확인되어 정비 작업 배경이 필요한 상태입니다. 특정 이용 또는 운영 작업을 위해 임시로 예약된 상태입니다.

그림. 자전거상태 변경화면

시나리오 5 증적 3. 상태변경 HTTP 요청

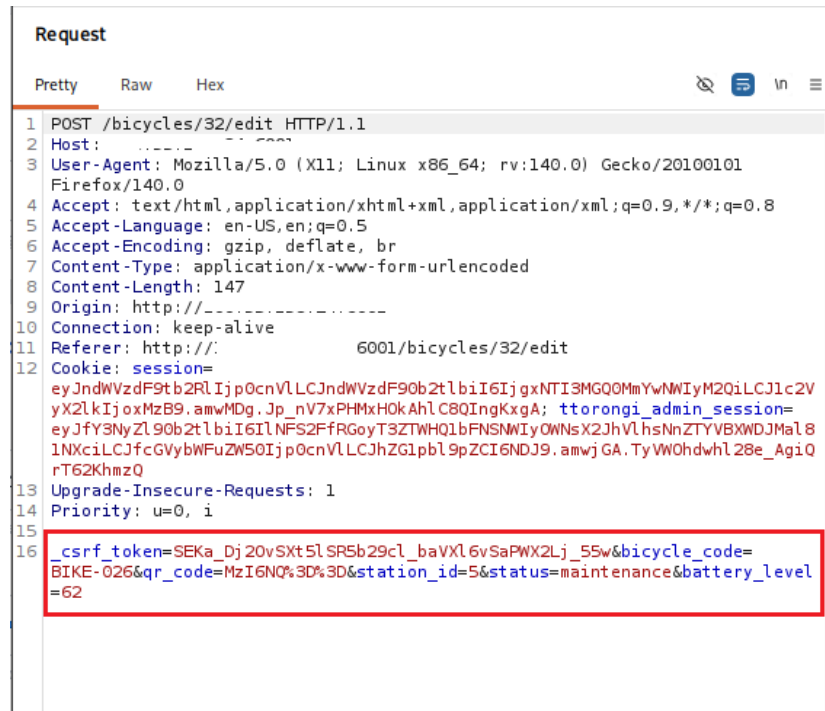


그림. 상태변경 HTTP 요청

시나리오 5 증적 4. 기존감사로그 미기록 DB

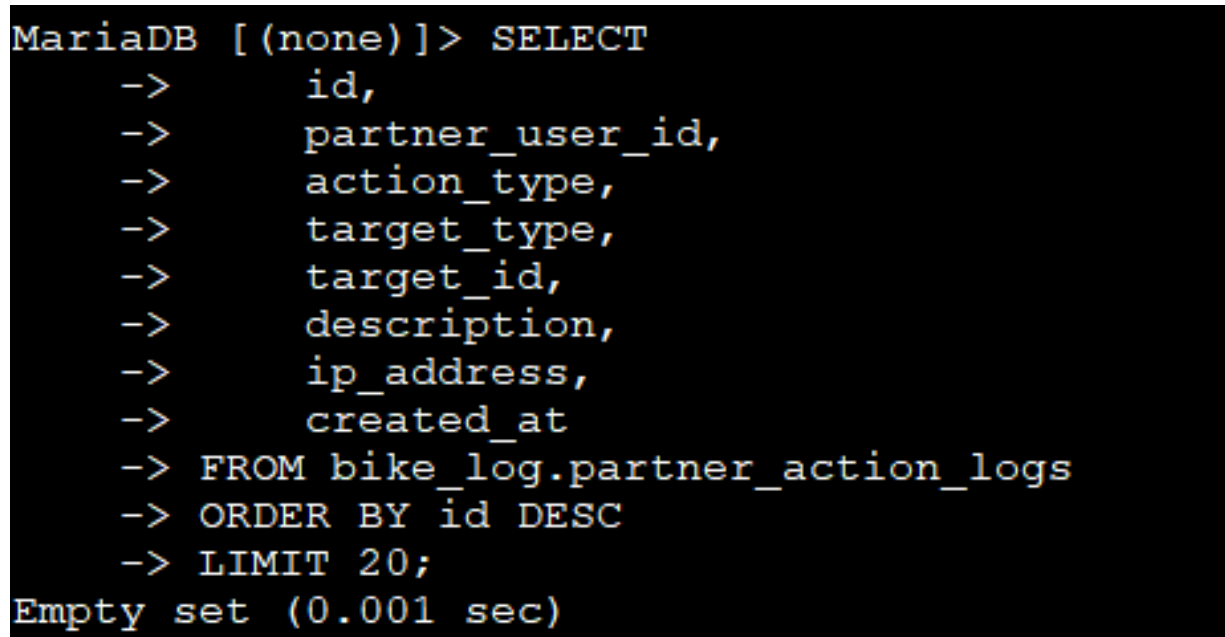


그림. 기존감사로그 미기록 DB

시나리오 5 증적 5. 기존감사로그 미기록 재확인

```
MariaDB [(none)]> SELECT
    ->     id,
    ->     partner_user_id,
    ->     action_type,
    ->     target_type,
    ->     target_id,
    ->     description,
    ->     ip_address,
    ->     created_at
    -> FROM bike_log.partner_action_logs
    -> ORDER BY id DESC
    -> LIMIT 20;
Empty set (0.001 sec)
```

그림. 기존감사로그 미기록 재확인

시나리오 5 증적 6. Wazuh 상태변경 탐지목록

	timestamp	agent.name	rule.description	rule.level	rule.id
	Aug 3, 2026 @ 16:00:51.740	logserver	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함	8	114401
	Aug 3, 2026 @ 14:31:41.165	logserver	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함	8	114401
	Aug 3, 2026 @ 14:30:29.136	logserver	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함	8	114401
	Aug 3, 2026 @ 14:27:11.069	logserver	[A09] 감사정보가 누락된 자전거 상태 및 배치 변경이 연속으로 수행됨	12	114402
	Aug 3, 2026 @ 14:26:07.053	logserver	[A09] 감사 추적정보가 누락된 자전거 운영정보 변경이 발생함	8	114401

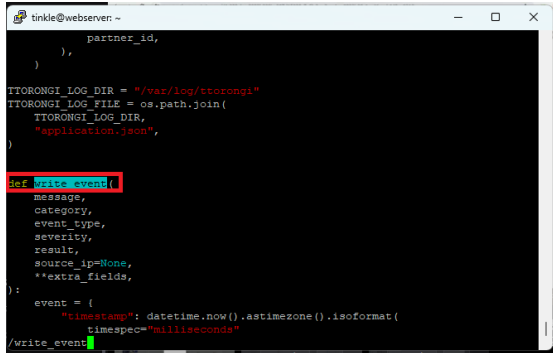
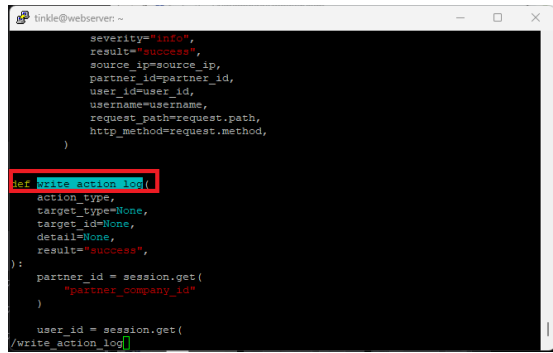
그림. Wazuh 상태변경 탐지목록

개선 방안

통제 영역	상세 적용 내용
업무 승인	maintenance→available 전환은 완료된 정비 작업지시서와 승인 권한을 필수로 확인한다.
감사 필드	actor_id, username, role, source_ip, bicycle_id, before, after, reason, work_order_id, result 를 구조화 기록한다.
원자성	업무 변경과 감사로그 INSERT 를 동일 DB 트랜잭션으로 처리한다.
불변성	감사로그 수정·삭제 권한을 분리하고 Wazuh 로 즉시 전달해 중앙 보존한다.
상관 탐지	동일 자전거 상태변경+재배치, 단시간 다수 변경, 승인 없는 변경을 고위험으로 탐지한다.

개선 적용 코드

자전거 상태 변경 시 DB 상태값만 수정하던 방식에 감사로그 기록 절차를 추가하였다. 수행 계정, 역할, 대상 자전거, 변경 전·후 상태, 요청 IP, 처리 결과가 함께 기록된다.

변경 전	변경 후
 <pre> def write_event(message, category, event_type, severity, result, source_ip=None, **extra_fields,): event = { "timestamp": datetime.now().astimezone().isoformat(timespec="milliseconds") } write_event(</pre>	 <pre> severity="info", result="success", source_ip=source_ip, partner_id=partner_id, user_id=user_id, username=username, request_path=request.path, http_method=request.method,) def write_action_log(action_type, target_type=None, target_id=None, detail=None, result="success",): partner_id = session.get("partner_company_id") user_id = session.get(write_action_log(</pre>

대응 전략

1. 연속 변경 Alert 에서 계정, source_ip, bicycle_id 와 발생 순서를 식별한다.
2. 해당 협력업체 세션을 중지하고 추가 변경을 차단한다.
3. DB 이력·작업지시서·웹 로그를 대조해 정상 상태와 위치를 복원한다.
4. 실물 자전거 상태를 현장 확인해 안전사고 가능성을 제거한다.
5. 동일 계정이 다른 자전거를 변경했는지 전수 조사하고 필요 시 권한을 회수한다.

보안 적용 후 변화

보안조치 및 재검증 중적

시나리오 5 재검증 1. 감사로그 생성목록

	timestamp	agent.name	rule.description	rule.level	rule.id
	Aug 3, 2026 @ 15:11:51.133	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023
	Aug 3, 2026 @ 15:11:51.121	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023
	Aug 3, 2026 @ 14:36:10.152	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 ...	11	120024
	Aug 3, 2026 @ 14:36:10.143	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 ...	11	120024
	Aug 3, 2026 @ 13:56:27.059	ttorongi-web	[A01] 타 사용자의 대여 상세정보가 비인가 사용자에게 노출됨	13	110104

그림. 감사로그 생성목록

시나리오 5 재검증 2. 감사로그 재검증목록

	Aug 3, 2026 @ 15:11:51.133	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023
	Aug 3, 2026 @ 15:11:51.121	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023
	Aug 3, 2026 @ 14:36:10.152	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 ...	11	120024
	Aug 3, 2026 @ 14:36:10.143	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여번호 직접 지정 강제 반납 ...	11	120024
	Aug 3, 2026 @ 13:56:27.059	ttorongi-web	[A01] 타 사용자의 대여 상세정보가 비인가 사용자에게 노출됨	13	110104
	Aug 3, 2026 @ 13:30:32.353	ttorongi-waf	[TTORONGI-01][A01][WAF] 대여 상세 객체 식별자 접근 요...	8	120023

그림. 감사로그 재검증목록

재점검

성공 기준

승인되지 않은 상태전환과 재배포를 시도한 뒤 승인된 작업지시서로 정상 변경한다. 미승인 요청은 거부되고 정상 요청에는 행위자·대상·전후 값·사유·작업지시서가 모두 기록되어야 한다.

5. 종합 개선 계획

5.1 조치 우선순위

우선순위	조치 항목	대상	완료 기준
P1	대여 객체 소유권 검증 및 강제 반납 차단	USER 5000	타 사용자 요청 HTTP 403, 상태 미변경
P1	동시 대여 트랜잭션·잠금·조건부 UPDATE 적용	USER/DB	동일 자전거 활성 대여 1 건
P1	정적 공개 운영자료 제거 및 인증 다운로드 적용	PARTNER 7000	비인증 요청 HTTP 401/403
P2	QR 서명·만료·일회성 검증 적용	USER 5000	변조·재사용 요청 차단
P2	운영변경 상세 감사로그 및 상관 Rule 개선	PARTNER/Wazuh	행위자·대상·전후 값·사유 확인
P3	WAF·pfSense 최소권한 룰과 탐지 튜닝	인프라	불필요한 직접 접근 차단 및 로그 확인

5.2 공통 보안 설계 원칙

- 모든 중요 객체 요청은 서버 측에서 인증된 사용자와 객체 소유권·역할을 함께 검증한다.
- 자전거 상태 변경과 대여 생성처럼 연결된 업무는 원자적 트랜잭션으로 처리한다.
- DMZ 의 WAF·WEB·DNS 와 내부 서버망의 DB·LOG 사이에는 필요한 포트만 허용한다.
- 모든 서버와 보안장비 로그를 Wazuh 로 수집하되 이벤트에 사용자·대상·결과·요청 경로·출발지 IP 를 포함한다.
- 운영자료는 웹 정적 경로가 아닌 인증된 전용 다운로드 경로로 제공한다.

5.3 권장 Wazuh 탐지 항목

탐지 시나리오	상관 조건	권장 대응
객체 소유권 불일치	동일 계정의 다수 rental_id 접근	세션 만료·계정 잠금

탐지 시나리오	상관 조건	권장 대응
QR 변조 탐색	짧은 시간 내 다수 invalid_qr_attempt	IP 제한·추가 인증
중복 대여	동일 bicycle_id 의 복수 rental_started	중복 대여 중지·자산 상태 점검
운영자료 다운로드	비인증 /static/exports/ HTTP 200	경로 차단·유출 범위 조사
연속 운영정보 변경	동일 자전거 상태변경+재배치	계정 중지·변경 원복

6. 재점검 기준 및 결론

6.1 취약점별 재점검 기준

시나리오 / OWASP	재점검 요청	성공 기준
시나리오 1 (A01)	test1 세션으로 test2 rental_id 조회·반납	HTTP 403, test2 대여 상태 유지, 차단 이벤트 생성
시나리오 2 (A02)	Base64 방식의 변조 QR 및 재사용 토큰 전송	연속 조회 화면 비교, 변조·재사용 토큰 검증 실패, 대여 미생성
시나리오 3 (A04)	동일 QR 을 서로 다른 세션으로 병렬 전송	첫 요청만 성공, 활성 대여 1 건, 차단 이벤트
시나리오 4 (A05)	쿠키 없이 기존 exports URL 요청	HTTP 401/403, 파일 미노출, 접근 차단 Alert
시나리오 5 (A09)	상태 변경과 재배치 연속 수행	행위자·대상·전후 값·사유 기록, 미승인 작업 거부

6.2 종합 결론

종합 평가	도룡이 웹서비스에서는 객체 단위 인가, 동시성 제어, 운영자료 접근통제 및 감사 추적 측면의 취약점이 확인되었다. 동시에 각 공격 행위가 애플리케이션 JSON 로그와 Wazuh Alert 로 수집되는 것을 확인하여 탐지 체계의 기반도 검증하였다. 우선순위 P1 항목을 먼저 보완한 뒤 동일 절차로 재점검해야 한다.
-------	--

- A01, A04, A05 의 고위험 취약점에는 객체 소유권 검증, 동시성 제어 및 운영자료 접근통제를 적용하였다.

- A02 에는 QR 토큰의 무결성·만료·재사용 검증을 적용하여 변조 요청이 대여 생성으로 이어지지 않도록 보완하였다.
- A09 에는 행위자·대상·변경 전후 값·요청 IP·처리 결과를 포함한 구조화 감사로그를 적용하였다.
- 동일 공격을 재수행한 결과 5 개 항목 모두 보완 기능이 정상 적용된 것을 확인하였다.

— 보고서 끝 —